AIEP
de la Universidad Andrés Bello

Introducción al Monitoreo y Modelo AAA

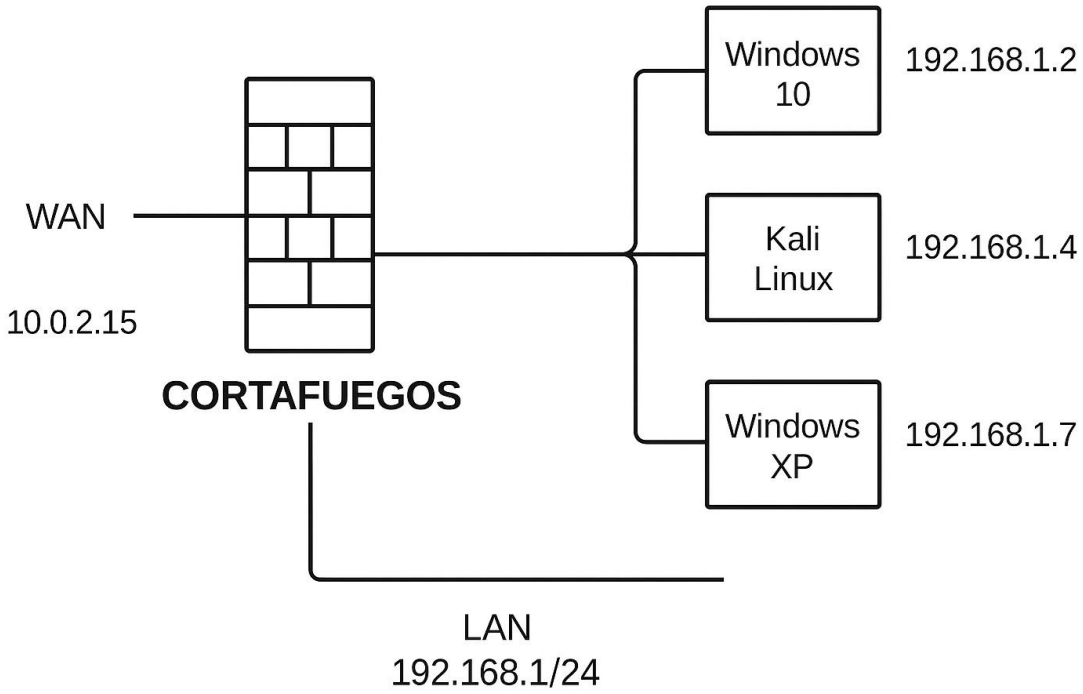
Ciberseguridad en Networking

Objetivos

AE2: Realizan gestión de mecanismos de seguridad en redes, considerando roles de seguridad, monitoreo de dispositivos y aplicación del modelo de autenticación, autorización y contabilidad para control de acceso.

OA: Diferenciar roles de seguridad en redes, considerando administradores, auditores y analistas de seguridad, de acuerdo con su impacto en la protección de infraestructura

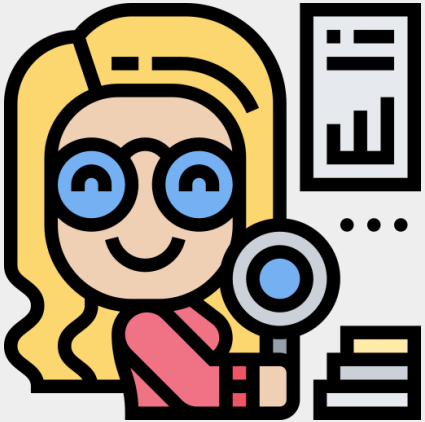
Infraestructura de Red



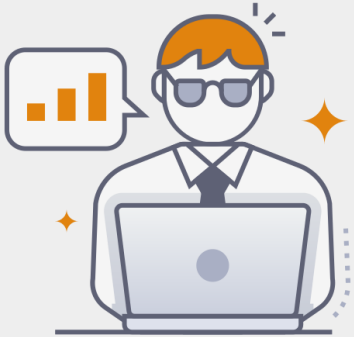
Roles de Seguridad en Redes

ROL: función que alguien o algo desempeña

Administrador de Seguridad
Security Administrator



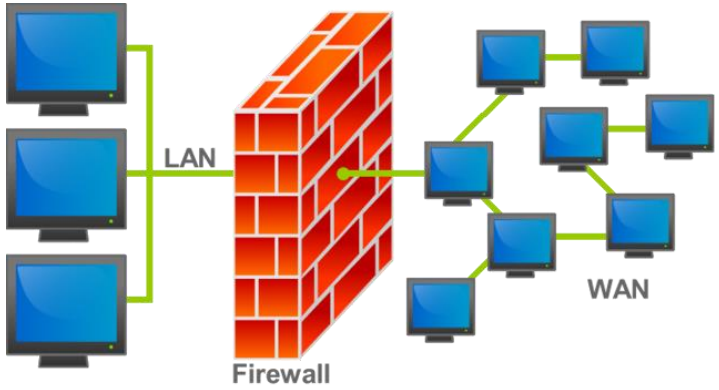
Auditor de Seguridad
Security Auditor



Analista de Seguridad
Security Analist

Introducción al Monitoreo y AAA

- El monitoreo detecta eventos anómalos (ej. intentos de acceso fallidos, caídas de servicios).
- AAA (Autenticación, Autorización y Contabilidad) garantiza que:
  - Solo usuarios válidos acceden.
  - Solo realizan acciones permitidas.
  - Sus acciones quedan registradas.
- Permite responder rápido a incidentes y fortalecer la seguridad.



En seguridad de redes no basta con poner contraseñas o un firewall, necesitamos **ver lo que ocurre dentro de la red en todo momento**. SNMP y Syslog nos permiten monitorear dispositivos, mientras que AAA nos asegura que todo acceso esté controlado y registrado. Esta base es fundamental para detectar anomalías a tiempo y cumplir con buenas prácticas como las establecidas en ISO 27001.

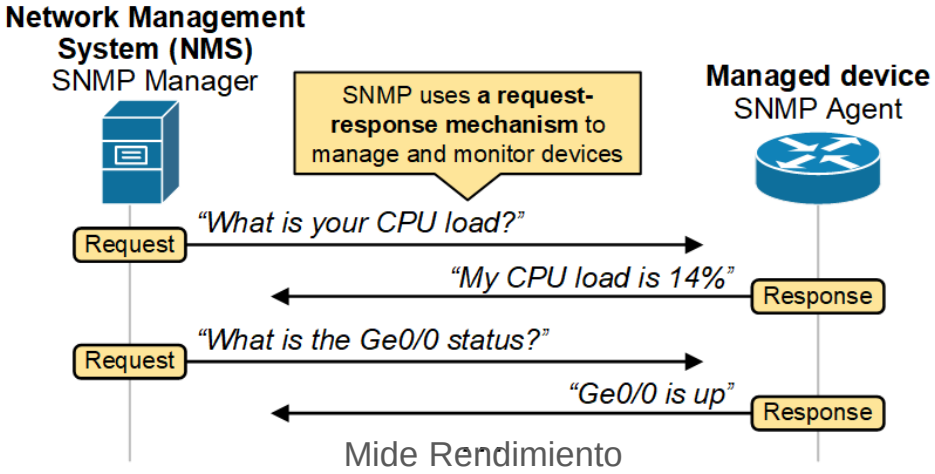
SNMP y Syslog

SNMP (Simple Network Management Protocol):

- Permite monitorear dispositivos de red (routers, switches, firewalls).
- Recolecta información como: uso de CPU, memoria, tráfico de red.
- Usa agentes instalados en los dispositivos.

Syslog:

- Sistema estándar para recopilar y centralizar **logs** de red.
- Registra eventos como: accesos, errores, intentos fallidos de autenticación.
- Facilita auditorías y respuesta a incidentes.



Mide Rendimiento

09-06-2012	16:44:40	Local7.Debug	10.100.1.192	Test user connected to website http://204.160.214.145/index.html
09-06-2012	16:44:39	Mail.Error	10.100.1.192	Test user connected to website http://196.182.33.60/index.html
09-06-2012	16:44:38	UUCP.Alert	10.100.1.192	Test user connected to website http://209.214.132.220/index.html
09-06-2012	16:44:37	Local2.Warning	10.100.1.192	Test user connected to website http://218.112.12.113/index.html
09-06-2012	16:44:36	System5.Notice	10.100.1.192	Test user connected to website http://207.212.93.24/index.html
09-06-2012	16:44:35	UUCP.Critical	10.100.1.192	Test user connected to website http://212.127.130.92/index.html
09-06-2012	16:44:34	Local2.Alert	10.100.1.192	Test user connected to website http://222.245.162.138/index.html
09-06-2012	16:44:33	User.Notice	10.100.1.192	Test user connected to website http://214.185.211.162/index.html
09-06-2012	16:44:32	User.Critical	10.100.1.192	Test user connected to website http://213.153.135.176/index.html
09-06-2012	16:44:31	System0.Critical	10.100.1.192	Test user connected to website http://211.94.23.143/index.html
09-06-2012	16:44:30	Local3.Info	10.100.1.192	Test user connected to website http://208.183.114.103/index.html
09-06-2012	16:44:29	Kernel.Notice	10.100.1.192	Test user connected to website http://200.195.17.96/index.html

Registra mensajes y logs

Ej) Un router envía vía Syslog alertas de múltiples intentos fallidos de login

SNMP → mide y notifica sobre el **estado operativo** de los dispositivos (rendimiento).

Syslog → guarda un **historial detallado de eventos y acciones** ocurridas en los equipos.

SNMP te avisa que un puerto cayó → Syslog te dice **por qué** cayó (ej: error de autenticación o cambio de configuración).

AAA: Autenticación, Autorización y Contabilidad

Autenticación:

- Verifica la identidad del usuario (¿quién eres?).
- Ejemplo: usuario + contraseña, MFA.

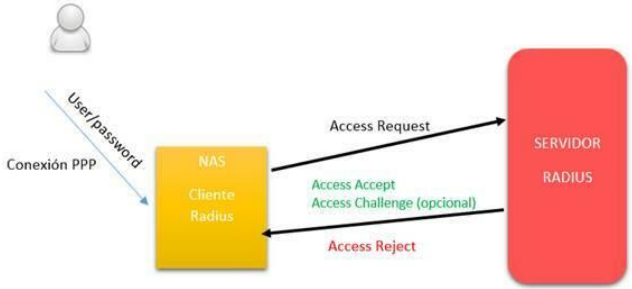
Autorización:

- Define qué acciones puede realizar (¿qué puedes hacer?).
- Ejemplo: un técnico puede reiniciar un servidor, pero no borrar logs.

Contabilidad:

- Registra las acciones ejecutadas (¿qué hiciste?).
- Ejemplo: logs de comandos en un switch.

Ej) Un usuario ingresa con sus credenciales (Autenticación), accede solo al área de facturación (Autorización) y queda registrado en los logs de acceso (Contabilidad).



El modelo **AAA** es la columna vertebral de la seguridad en redes. Nos asegura que cada acción esté respaldada: primero comprobamos la identidad, luego limitamos qué puede hacer el usuario, y finalmente dejamos huella de todo lo que se hizo. Esto permite detectar comportamientos indebidos y asignar responsabilidades en caso de incidentes.

RADIUS (Remote Authentication Dial-In User Service)

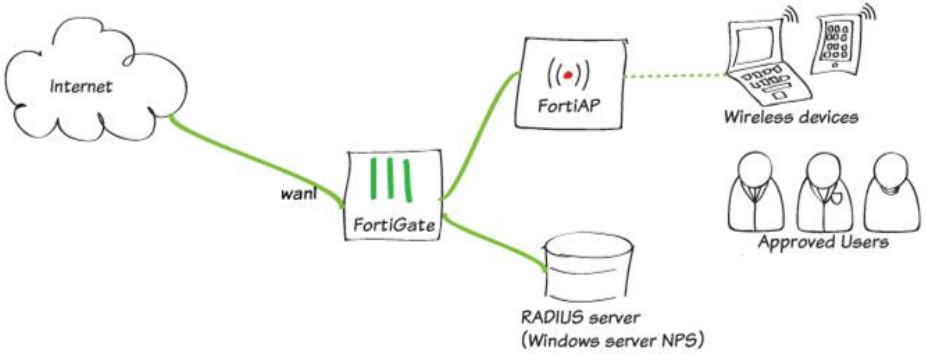
Es un **protocolo de autenticación y autorización** usado principalmente para dar acceso seguro a **usuarios finales** en redes.

Funciona con el modelo **cliente-servidor**:

- El dispositivo (ej. un AP Wi-Fi o VPN concentrator) actúa como **cliente RADIUS**.
- Un servidor central (RADIUS server) valida las credenciales contra una base de datos.

Se usa mucho en **Wi-Fi empresarial, redes VPN y acceso remoto**.

Ej) Un empleado se conecta al Wi-Fi de la oficina → el AP pregunta al servidor RADIUS si el usuario es válido → si lo es, lo deja entrar.



RADIUS es un protocolo de autenticación, autorización y contabilidad que puede ser utilizado por el portal cautivo para verificar las credenciales de los usuarios antes de concederles acceso a la red.

TACACS+ (Terminal Access Controller Access Control System Plus)

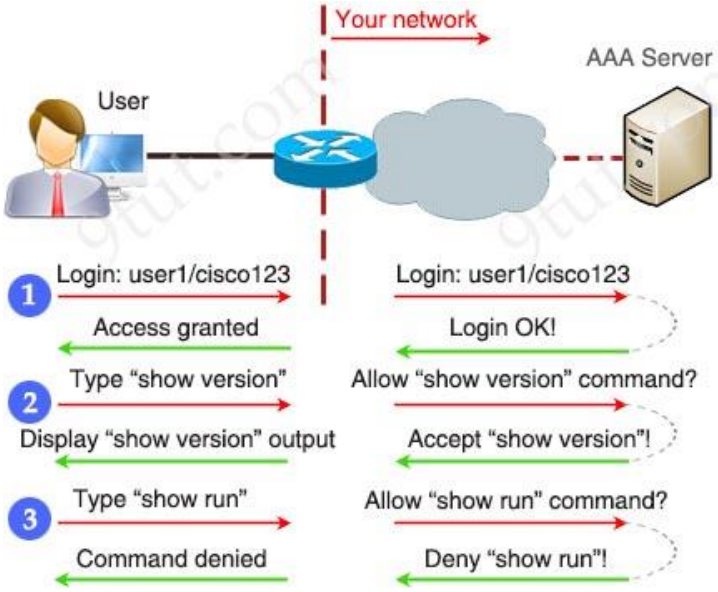
Es un protocolo desarrollado por Cisco (aunque soportado en varios equipos).

Implementa los 3 componentes de **AAA por separado**:

- **Autenticación** → ¿quién eres?
- **Autorización** → ¿qué puedes hacer?
- **Contabilidad** → ¿qué hiciste y cuándo?

Usa **TCP** (más seguro) y cifra toda la comunicación.
Se usa en la **administración de dispositivos de red** (routers, switches, firewalls).

Ej) Un técnico entra a un router → TACACS+ valida su usuario, le permite ejecutar solo ciertos comandos, y registra cada acción en un log.



Comparación RADIUS vs TACACS+

Aspecto	RADIUS	TACACS+
Función principal	Autenticación y autorización **para usuarios finales** (Wi-Fi, VPN, acceso remoto).	Autenticación, autorización y contabilidad **para administradores de red y equipos críticos**.
AAA	Maneja autenticación y autorización **juntos**.	Maneja AAA **por separado** (mayor control).
Protocolo	UDP (puerto 1812/1813).	TCP (puerto 49).
Seguridad	Solo la contraseña va cifrada.	Todo el paquete va cifrado.
Escalabilidad	Muy usado en redes grandes con muchos usuarios.	Usado donde se requiere **control detallado de administradores**.
Ejemplo de uso	Empleados se conectan al Wi-Fi corporativo.	Técnicos gestionan un router y cada comando queda registrado.

RADIUS → pensado para **usuarios finales** (Wi-Fi, VPN).
TACACS+ → pensado para **administradores de red y equipos críticos**.

Evaluación de eventos de seguridad en logs

Los **logs** registran toda la actividad en dispositivos y sistemas.

Permiten detectar **anomalías**:

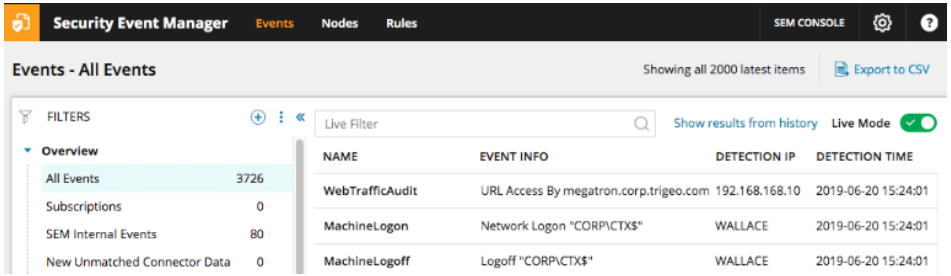
- Intentos de acceso fallidos repetidos.
- Cambios no autorizados en configuraciones.
- Tráfico inusual o errores de red.

El monitoreo debe ser **centralizado** (servidor Syslog, Sistema de Gestión de Eventos e Información de Seguridad (SIEM)).

Revisión periódica = clave para la **detección temprana de incidentes**.

```
Aug 26 19:25:33 Router01 sshd[1223]: Failed password for admin from 192.168.1.45 port 54421
Aug 26 19:25:36 Router01 sshd[1223]: Failed password for admin from 192.168.1.45 port 54421
Aug 26 19:25:39 Router01 sshd[1223]: Accepted password for admin from 192.168.1.45 port 54421
```

En este ejemplo vemos varios intentos fallidos y finalmente un acceso aceptado. Eso puede significar un ataque de fuerza bruta exitoso. Por eso no basta con almacenar registros, hay que **leerlos, analizarlos y reaccionar** con acciones correctivas. En entornos profesionales se usan sistemas como **SIEM (Security Information and Event Management)** para correlacionar estos eventos.



Acciones correctivas y buenas prácticas

- **Bloqueo inmediato** de usuarios sospechosos o direcciones IP maliciosas.
- **Cambio de contraseñas** y aplicación de **MFA** (autenticación multifactor).
- **Revisión de configuraciones** en dispositivos afectados (firewall, switches, routers).
- **Segmentación de red** para aislar sistemas críticos.
- **Notificación y escalamiento** del incidente al equipo responsable.
- **Documentación del evento** y aplicación de mejoras preventivas.

Acciones correctivas y buenas prácticas

```
Aug 30 19:12:03 Router01 sshd[2231]: Failed password for admin from 192.168.1.45 port 51234 ssh2
Aug 30 19:12:07 Router01 sshd[2231]: Failed password for admin from 192.168.1.45 port 51234 ssh2
Aug 30 19:12:11 Router01 sshd[2231]: Failed password for admin from 192.168.1.45 port 51234 ssh2
Aug 30 19:12:15 Router01 sshd[2231]: Failed password for admin from 192.168.1.45 port 51234 ssh2
```

¿Qué hacemos?

Acciones correctivas sugeridas

- Configurar bloqueo automático de IP tras X intentos fallidos.
- Habilitar alertas de Syslog para incidentes similares.
- Revisar si el intento corresponde a un usuario real (ej. empleado en esa PC).
- Reforzar políticas de contraseñas y autenticación.

Cierre

- **Monitorear** → Configurar **Syslog y SNMP** para detectar anomalías.
- **Controlar accesos (AAA)** → Usar **SSH, RADIUS/TACACS+**, roles y MFA.
- **Revisar logs** → Detectar intentos sospechosos y actuar rápido.
- **Responder** → Bloquear IPs, aislar dispositivos y documentar incidentes.
- **Prevenir** → Segmentar la red, actualizar configuraciones y aplicar buenas prácticas.